

DISTAF

**Digital Identity Systems
Trustworthiness Assessment
Framework**

2024

Executive Summary

This document introduces the Digital Identity Systems Trustworthiness Assessment Framework (DISTAF) and the methodology followed that led to the development of assessment criteria for a web-based tool for evaluating the Trustworthiness of Digital Identity Systems. DISTAF derives from the framework that describes the facets of trustworthiness in digital ID systems previously developed (Maple et al., 2021) as part of the Trustworthy Digital Infrastructure for Identity Systems project. This framework facilitates a comprehensive assessment of a given ID system against the different pillars and associated metrics identified in the framework. The DISTAF tool and assessment processes allow auditors and administrators to undertake a self-assessment to gauge the level of maturity achieved in the implementation of an ID system via assessment of both the design and the operational stages. The results of such an assessment provided a snapshot of trustworthiness in the areas of Security, Privacy, Ethics, Resiliency, Robustness and Reliability, allowing the system owner to fully understand their position and develop strategies to ensure their systems are trustworthy.

Acknowledgements

This work was supported, in whole or in part, by the Bill & Melinda Gates Foundation [INV-001309]. Under the grant conditions of the Foundation, a Creative Commons Attribution 4.0 Generic License has already been assigned to the Author's Accepted Manuscript.

The Institute is named in honour of Alan Turing, whose pioneering work in theoretical and applied mathematics, engineering and computing is considered to have laid the foundations for modern-day data science and artificial intelligence. It was established in 2015 by five founding universities and became the United Kingdom's (UK) National Institute for Data Science and Artificial Intelligence. Today, Turing brings together academics from 13 of the UK's leading universities and hosts visiting fellows and researchers from many international centres of academic excellence. Turing also liaises with public bodies and is supported by collaborations with influential organisations.

List of Figures

Figure 1 An example of a pillar with mechanisms and metrics	7
Figure 2 A generic hierarchy composed of different type of metrics.....	12
Figure 3 The context diagram.....	16
Figure 4 Mock-up of the login page.....	19
Figure 5 Mock-up of the authentication and authorisation use-cases.....	20
Figure 6 Mock-up of assessment creation.....	22
Figure 7 Mock-up of the assessment process, part 1.....	24
Figure 8 Mock-up of the assessment process, part 2.....	25
Figure 9 Mock-up of assessment report and comparison.....	27

List of Tables

Table 1 Functionalities allowed by each role	17
Table 2 Use case: Login User	19
Table 3 Use case: Register User.....	20
Table 4 Use case: Forgotten Password	21
Table 5 Use case: User changes password.	21
Table 6 Use case: Roles Management	21
Table 7 Use case: Assessments Search	23
Table 8 Use case: Assessment Creation	23
Table 9 Use case: Assessment Process, part 1.....	24
Table 10 Use case: Assessment Process, part 2.....	25
Table 11 Use case: Assessments Report.....	27
Table 12 Use case: Assessments Comparison	28

Contents

Executive Summary	2
List of Figures.....	3
List of Tables	3
1. Introduction	5
2. The self-assessment process	6
2.1 Homogeneous metrics' scores	7
2.2 Clustering metrics in mechanisms	9
2.3 Hierarchical scoring.....	11
2.4 Mandatory metrics	12
2.5 Resulting pillars and mechanisms	13
3. Users and roles.....	16
4. Use-cases and mock-up.....	18
4.1 Authentication and Authorisation	19
4.2 Assessment creation	22
4.3 Assessment process	24
4.4 Reports and comparison	27
5. Further information	29
6. References.....	29
Appendix A: Reference documentation for security pillar metrics	30
Appendix B: Reference documentation for privacy pillar metrics.....	31
Appendix C: Reference documentation for ethics pillar metrics.....	32
Appendix D: Reference documentation for robustness pillar metrics	33
Appendix E: Reference documentation for resilience pillar metrics	34
Appendix F: Reference documentation for reliability pillar metrics	35

1. Introduction

Electronic Identification can guarantee the unambiguous identification of a person and ensure that the correct service is provided to the rightful recipient, such as for banking purposes. Nonetheless, any disruptive change inevitably brings risks linked to the sensitive nature of the data. It is no longer sufficient to require the security and privacy of processes; instead, we must consider whether these systems are worthy of the users' trust.

Maple et al. (2021) proposed an evaluation framework where trustworthiness is composed of six fundamental pillars (facets), specifically Security, Privacy, Ethics, Resiliency, Robustness and Reliability. From those, 65+ primary mechanisms were identified, resulting in 300+ metrics taken from many technical reports, international standards, and guidelines. The effectiveness and adoption of such a complex framework necessarily pass from the availability of an immediate and usable tool for its assessment.

The assessment tool allows the user to decide at which level of detail to carry out the evaluation allowing some categories of users to be able to linger at higher levels, quickly capturing the coarse characteristics of the system considered. On the other hand, designers and developers can investigate further, diving into the metrics' details to identify ways of improvement. In both cases, however, it is worth noting that the tool is meant to be a companion or a reference, not to determine which EIDS implementation is better than the others, instead, to allow each of those to gauge on their level of trustworthiness in the design and operational stages of their digital identity system.

To support the user, this document explains in detail how the assessment process works, explaining the structure of the pillars and the calculation of the trustworthiness scores. It then provides a set of use-cases which demonstrate the functionality of the assessment tool and the

2. The self-assessment process

The main elements of the Digital Identity Systems Trustworthiness Assessment Framework (DISTAF) are the pillars, which are further broken down into mechanisms and metrics (see Figure 1). By assessing these aspects, users can accurately evaluate EIDS and measure the extent of their trustworthiness.

The framework is composed of hundreds of metrics, one of the main objectives of the tool is the ability to provide support in early phase of EIDS development, where users might only want to quickly estimate the trustworthiness level of a system, to identify possible directions of improvement and the corresponding effort. Therefore:

- a. For each mechanism, it is possible to define several common scenarios, that is, system configurations which can be selected by the assessor to quickly fill the underlying metrics. Note that it will always be possible to change the score of individual metrics, to better represent the EIDS under evaluation. The process of clustering metrics to mechanism configurations is explained in depth in a following section.
- b. Since most metrics are linked to standards and regulatory documents, the assessor has the possibility of confirming their compliance, automatically providing a score to fulfilled properties.

The reader should note the amount of technicality related to some metrics, which is not suitable for all audience, especially when the assessment must be tailored to exclude mechanisms not included in the current implementation of EIDS. To do so

- c. Each mechanism can be excluded from the assessment, whose metrics will not be considered for the final score of the pillar.

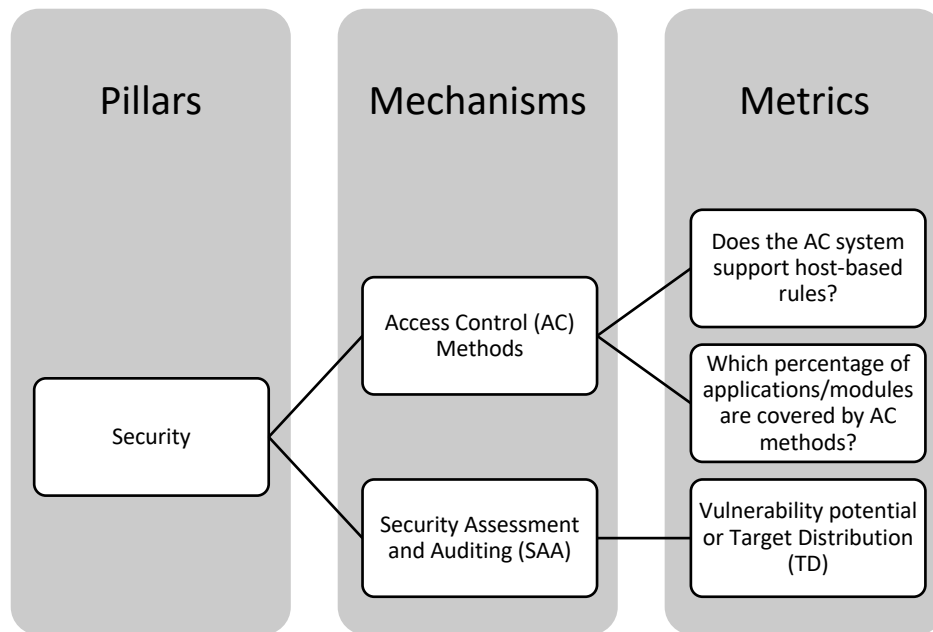


Figure 1 An example of a pillar with mechanisms and metrics

The system uses a scoring strategy suitable capable of aggregating metrics' scores to mechanisms (and therefore to pillars), excluding those unwanted. The same method also works in the opposite direction. It is possible to assign scores to a mechanism directly, choosing a pre-defined configuration, with a non-ambiguous way to propagate such values to the underlying metrics. In this way, no matter how the assessment is conducted, it will always be composed of a set of numerical values on the metrics, which can be used for the final evaluation, for example by developers/designers to identify possible improvements by executing a comparison with other systems. Furthermore, metrics are clustered into groups or mechanisms, resulting in a hierarchical structure.

2.1 Homogeneous metrics' scores

The framework uses different metrics: Boolean and percentage. Since we aim to aggregate scores, all metrics are implicitly converted to percentage type, as follows:

Boolean metrics (Y/N), which only accept Yes or No values, are used to declare if a particular system property was considered or implemented in the design and operational phases,

respectively. Those metrics are converted to percentages by mapping Y = 100%, N=0%. For example:

Metric	S.AAA.D9
Name	Provision for challenge-response protocols
Description	Challenge-Response protocols are the most common method of action authentication, where one side provides a challenge (to be replied to) and the other must present a correct response (to be checked/validated) to the challenge. They help in resolving certain cyber assaults, such as Replay, and prevent credentials from being transmitted over the network.
Pillar/Mechanism	Security -> Authentication-Authorization-Accounting (AAA)
Phase	Design
Score	Y/N

Percentage metrics (%) are used to define the part of the system subject to external auditing or the level of compliance with an international standard. In all cases, metrics have values between 0% and 100%, where 100% is the desirable situation, and 0% indicates an unfavourable condition. In auditing, the value 0% means that no part of the system is subject to external auditing, whilst the value 100% indicates that the whole system is covered. In some cases, original metrics had different semantics, as in the case of the percentage of the system vulnerable to cyber-attacks, where the value of 0% is the optimal scenario. To allow subsequent aggregation, those metrics were sanitised to make their values homogeneous with the rest of the framework. For example:

Metric	S.SAA.O10
Name	False Rejection Rate (FRR)
Description	FRR is the probability (0-100%) that the AAA system does not detect a match between the user-provided input and the corresponding entry in the database. Or, equivalently, it

	estimates the percentage of valid inputs that are incorrectly rejected.
Pillar/Mechanism	Security -> Authentication-Authorization-Accounting (AAA)
Phase	Operational
Score	100%-FRR

2.2 Clustering metrics in mechanisms

The clustering phase was highly delicate and complex due to the number and heterogeneity of the metrics involved. For this reason, an iterative approach was necessary, which required a careful analysis of the results obtained to identify the most significant clusters and to be able to label them properly. The methodology derives from the thematic analysis (Braun & Clarke, 2006).

All entries were coded and interlinked to emphasise the metrics shared among different mechanisms. After that, clustering was processed at the level of the mechanisms, trying to minimise the intrinsic loss of accuracy, which is inevitable in making this action. Specifically, only the metrics concerning the same concept or aspect of the system were considered. Furthermore, those metrics were grouped only if it is possible to formulate a question, usually multiple-choice, whose answers can be represented as configurations of the original metrics. As an example, consider the following two metrics:

Metric	S.AC.D8
Name	Does the AC system support host-based rules?
Description	Host-based access control specifies which users (or user groups) are permitted to access particular hosts (or host groups) via specific services (or services in a service group). This allows you to restrict access to a particular system in your domain to a specific user group and to permit just a particular service to access the systems in your domain.
Pillar/Mechanism	Security -> Access Control (AC) Methods

Phase	Design
Score	Y/N

Metric	S.AC.D9
Name	What is the level of configurability of the AC system?
Description	This metrics refers to the level of configurability of AC controls.
Pillar/Mechanism	Security -> Access Control (AC) Methods
Phase	Design
Score	0 (0%) - Not configurable 1 (25%) - Limited configuration possibilities 2 (50%) - Standard configuration possibilities 3 (75%) - Role-based or advance configuration possibilities 4 (100%) - Capable of handling possible future policy changes

Suppose the system allows a level of AC configuration so powerful to handle possible future policy changes, expressed by metric S.AC.D9. In that case, it is reasonable to suppose it can also support host-based policies, referred by metric S.AC.D8. Those metrics are then good candidates to be merged in a cluster with the following multiple-choice question:

Cluster	AC Configurability
Pillar/Mechanism	Security -> Access Control (AC) Methods
Phase	Design
Question	What is the level of AC configurability?
Answers	0 - limited or no configurability (S.AC.D8=N, S.AC.D9=0%) 1 - simple level of configurability (S.AC.D8=N, S.AC.D9=25%) 2 - advanced configuration (S.AC.D8=N, S.AC.D9=75%) 3 - support for current and future policies (S.AC.D8=Y, S.AC.D9=100%)

Each possible answer also provides the corresponding configuration of underlying metrics, which is needed for score propagation (see the following section).

There are other cases, however, where metrics cannot be easily clustered, especially when the multiple-choice question would include all possible configurations of the underlying metrics, failing to simplify the assessment. We only consider the most common scenarios in those cases, covering only a subset of metric configurations. The user has always the possibility of drilling down to metrics for finer granularity.

2.3 Hierarchical scoring

The final step is to provide a rigorous way to compute pillars' scores from metrics. To better explain how this aggregation works, we shall consider a generic hierarchy, as shown in Figure 2. Three steps are executed:

1) Score propagation to metrics

For each pillar, X

For each mechanism X_x (not excluded from the assessment)

If the score is assigned to mechanism, it must be propagated to metrics $X_x^{(n)}$ according to the formula stored in the mechanism itself.

2) Score aggregation to mechanisms

For each pillar X

Compute the score of each mechanism X_x (not excluded from the assessment) as the weighted sum of the underlying metrics, eventually converted to a percentage, as follows:

$$score_{X_x} = \sum score_{X_x^{(n)}} \cdot W_x^{(n)}$$

3) Score aggregation to pillars

Compute the score of each pillar X as the weighted sum of the underlying mechanisms, as follows:

$$score_X = \sum score_{X_x} \cdot W_x$$

Note that pillars are not aggregated, as they provide entirely different perspectives on the system. However, within each pillar, weights allow modulating the significance of mechanisms and metrics. By default, weights have a default value of $1/n$, n is the number of elements, treating all mechanisms (and metrics) as equally important.

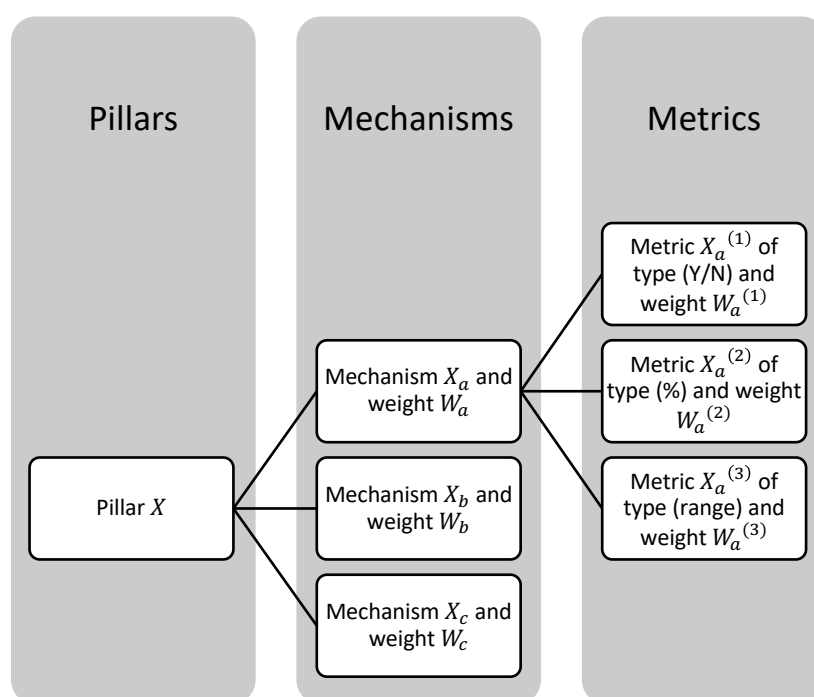


Figure 2 A generic hierarchy composed of different type of metrics

2.4 Mandatory metrics

Aggregation of metrics is a powerful approach, but it also hides a subtle disadvantage: it is possible to achieve medium-high score at mechanism level (or even pillar) despite the fact one or more important metrics are not satisfied. As an example, having an automated password recovering system (operational metric RES.IDR.O6) is fundamental for the “ID recovery” mechanism in the Resilience pillar: without such metric being satisfied, the mechanism itself cannot be considered sufficiently designed and/or implemented. These mandatory metrics are easily understandable in the Security pillar: they coincide with the set of quantifiable measures that organizations must implement and monitor to ensure the effectiveness of their security controls and compliance with relevant regulations, standards, or policies. To model the significance of such fundamental metrics, the tool allows the

definition of two caps, for the mechanism and for the pillar, respectively. For example, metric RES.IDR.O6 may have caps 40-80, which means that, if not satisfied, the maximum aggregated score at the mechanism level is limited to 40%. Concurrently, the aggregated score at the pillar level is limited to 80%. It is also possible not to limit pillar score, setting the second cap to 100%. To facilitate the comprehension of mandatory metrics, the tool will use a different background colour (purple) to emphasise that the score has been capped by an unsatisfied metric.

2.5 Resulting pillars and mechanisms

In the following tables we introduce each pillar with the corresponding mechanisms. Please view the appendices in this document to understand which standards and reference documentation were used to develop the metrics contained within each mechanism.

Pillar	Security
Mechanisms	• Access Control (AC) Methods • Security Assessment and Auditing (SAA) • Authentication-Authorisation-Accounting (AAA) • Identity Governance and Intelligence • Evidence of Layered-Security • Defence-in-depth • Personal Identifiable Information (PII) and Sensitive PII (SPII) • Regulatory Compliance (DID assurance) • Cryptographic protection • Maturity level of security policies in place • SSO or federated access Mngt support • Vulnerability Management • Systems & Communications Protection

Pillar	Privacy
Mechanisms	• Remote Identity Proofing and Non-Face-to-face Onboarding

	• Use Limitation • Privacy Impact Assessment (PIA) • Privacy Risk Mitigation Plans • Well defined privacy models and policies • Secondary use service • Privacy Standard(s) • Troubleshooting identity proofing
--	---

Pillar	Ethics
Mechanisms	• Data and process provenance • Evidence of user empowerment to monitor use and potential misuse • "Openness" of systems and algorithms managing the DIMS • Audit-trail on how the Identity was used • Decisions are made in an appropriate manner based on users' consent

Pillar	Reliability
Mechanisms	• Streamlined user contact points and processes • EIDS sufficient Assurance Levels against Fraud risks • Government approved audits Evidence of assurance assessment • Handling unexpected termination and unexpected actions

Pillar	Resiliency
Mechanisms	• EIDS Internet face protection • Internal EIDS security processes enforced • Back up and Disaster Recovery Plans

	• Cyber resilience strategy in place • Demonstrate balance between preventive and detective controls • Reaction to Security incidents against the EIDS • ID recovery
--	---

Pillar	Robustness
Mechanisms	• Expected outcomes from unexpected inputs • In time provisioning and de-provisioning processes • Tolerate process variability in operating and environmental conditions • Evidence of maintainability Requirements

3. Users and roles

The use of the tool requires the recognition of the connected user, from which the roles and permissions are extracted. The diagram in Figure 3 elicits the context of the tool, with all the roles and users involved.

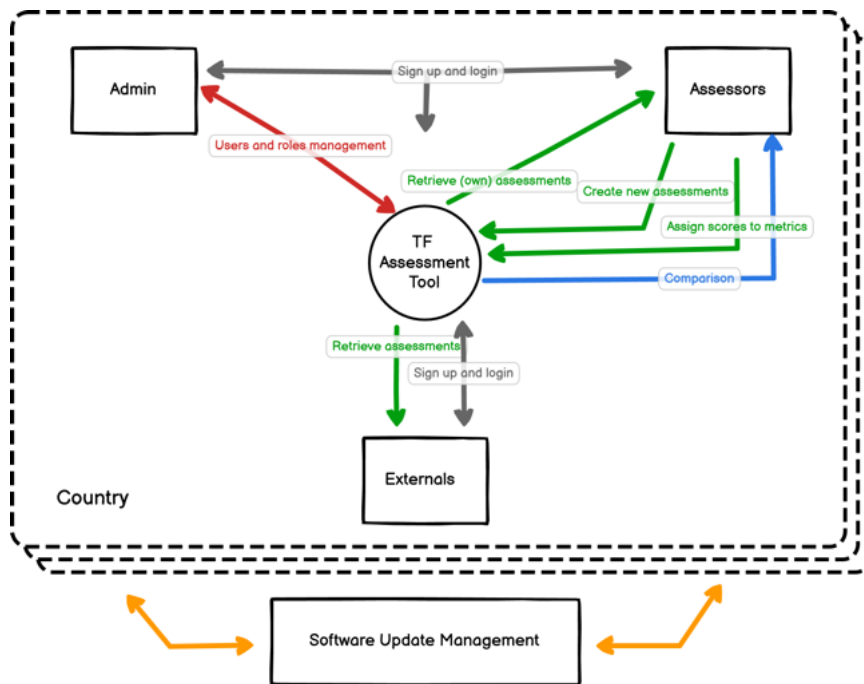


Figure 3 The context diagram

The **Software Update Management** is a universal user who is responsible for creating and maintaining the official hierarchy of metrics: with time, new metrics and mechanisms could be added to the framework, while others shall be removed. When a new version of the hierarchy is released, it is vital that existing assessments remain linked to the original metrics. Furthermore, all new assessments, even the ones stemming from previous versions, will inherit the new hierarchy composition.

Each country has its own specific copy of the tool, with a separate database containing both users and assessments. Inside each country, we can find three main actors interacting with the tool:

- **Assessors** are users who are responsible to create and manage assessments. An assessor can retrieve the complete list of existing assessments, and to create new ones

from an empty template or as a new version of a previous entry. Moreover, the assessor is the only entity who can compare two existing assessments.

- **Externals** are users who can access assessments defined as public, however, in a read-only fashion. They can export a report of the chosen assessment, without the possibility to compare.
- The **admin** is the user responsible to manage the credentials and roles of other users. He can add new users to specific roles, disable access, and regenerate temporary passwords.

Table 1 summarises the functionalities and data visibility criteria of each role. (*) indicates only public assessments.

Table 1 Functionalities allowed by each role

Group	Functionality	Admin	Assessor	External
Authentication & Authorisation	Login/Logout.	Yes	Yes	Yes
	Changing own password.	Yes	Yes	Yes
	Temporarily changing others' password.	Yes	No	No
	Changing roles to users	Yes	No	No
	Granting or revoking access to users.	Yes	No	No
	Registering a new user.	Yes	No	No
Assessment Management	Viewing the list of assessments.	Yes	Yes	Yes (*)
	Viewing an assessment's details	Yes	Yes	Yes (*)
	Creating a new blank assessment.	Yes	Yes	No
	Creating a new version of assessment.	Yes	Yes	No
	Deleting an existing assessment.	Yes	Yes	No
	Editing an existing assessment.	Yes	Yes	No
	Exporting assessment data.	Yes	Yes	Yes
Reporting	Extracting assessment reports.	Yes	Yes	Yes (*)
	Extracting comparison reports.	Yes	Yes	No

4. Use-cases and mock-up

This section provides a set of use cases and mock-up diagrams as a guide to the functionality and purpose of the DISTAF assessment tool. The use cases include the set-up and execution of an assessment, and the reporting functions available to the user. These are for oversight, for more granularity please use the user manual.

Each use case is composed of the following fields:

Summary - a top-level overview of the Use Case and the desired outcome.

Basic flow - Steps followed to execute the Use Case (including responsibilities of identified Actors).

Alternate flow(s) - Steps which support the execution of the Use Case but may not feature every time the Use Case is executed.

Pre-conditions - Things which the solution can assume to be true prior to the commencement of the Use Case.

Post-conditions – Things which can assumed to be true because of successful execution of the Use Case.

4.1 Authentication and Authorisation

Figure 4 Mock-up of the login page.



Table 2 Use case: Login User

Use Case Name:	Login User
Summary:	A user must log in for the system to determine his access level. The login process requires the insertion of credentials, composed by the pair <username, password>. If the inserted credentials are correct, the user is redirected to the home page. Otherwise, a generic error message should be visualised, without eliciting which input is invalid. There should be a maximum number of login attempts, to block possible brute-force attacks.
Basic Flow:	1. When accessing the application, the user is automatically redirected to the login page. 2. The system requests the username and password. 3. The user enters his username and password. 4. The system verifies the username and password against all registered users. 5. The system starts a new authenticated session, redirecting the user to the homepage.
Alternative Flows:	3a. if the username is empty, an error message should be displayed to the user. 4a. if the username or the password are incorrect, an error message should be displayed to the user. Go to step 2. 4b. if the user inserted wrong credentials for three times, the login process is stopped.
Pre-conditions:	The user is registered, and the account is active.
Post-conditions:	The user can access the homepage and the rest of the application.

Figure 5 Mock-up of the authentication and authorisation use-cases.

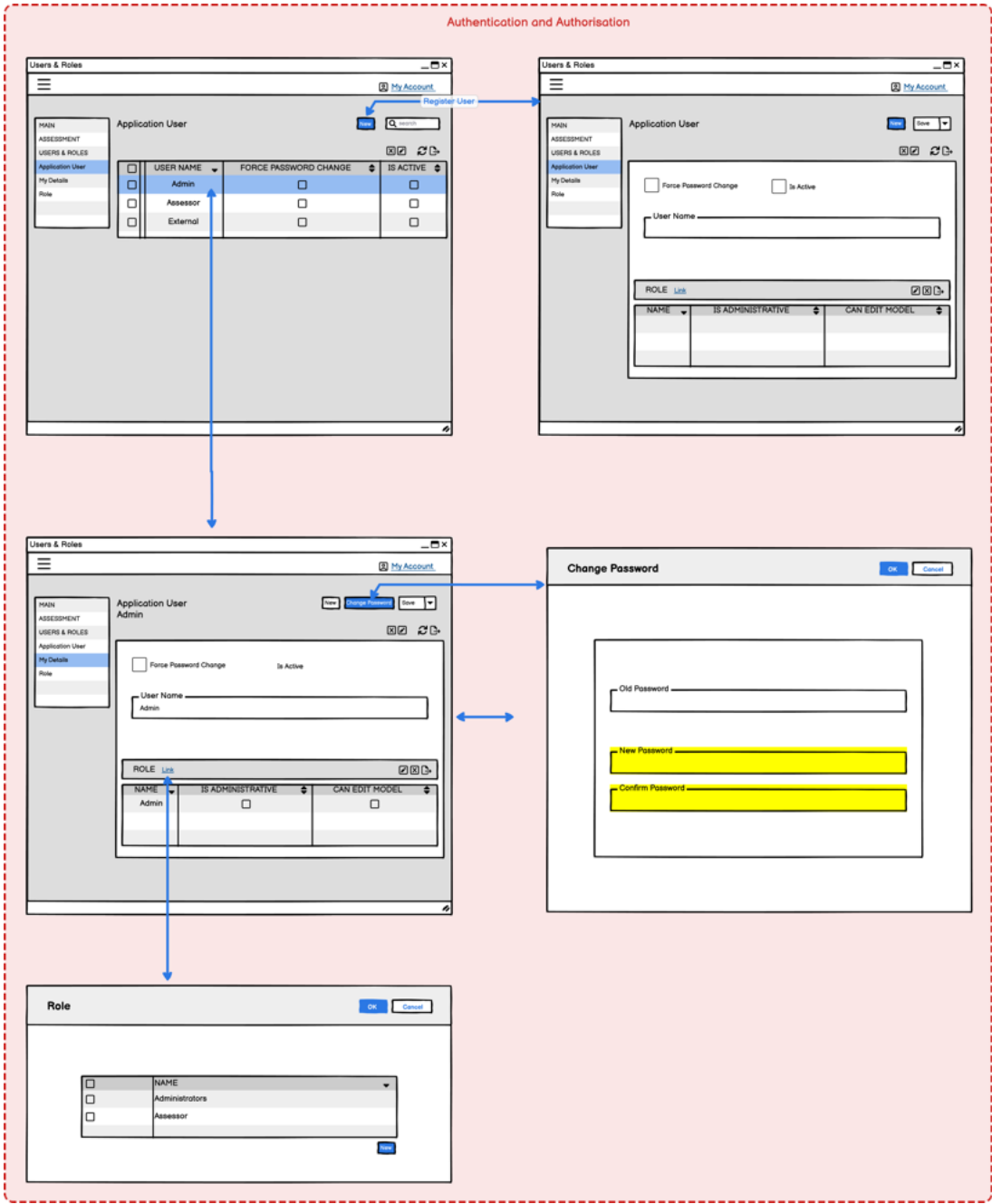


Table 3 Use case: Register User

Use Case Name:	Register User
Summary:	Considering the specific nature of the tool, new users are created by the country administrator who set the role contextually. The administrator may ask the user to change his own password at first log-on.
Basic Flow:	1. The administrator navigates to the users/roles page.

	2. The administrator executes a “New” action and enters the details of the new user. 3. The system checks that the username is not already existing. 4. The administrator assigns a role to the user, with the use-case “Roles Management”. 5. The administrator saves and creates the new user. 6. The administrator can assign an initial password to the user by initiating use-case “Forgotten Password”
Alternative Flows:	2a. if the username is duplicated, repeat step 2.
Pre-conditions:	Current user has administrator access.
Post-conditions:	A new user is created in the system, with a corresponding role and permissions on data and functionalities.

Table 4 Use case: Forgotten Password

Use Case Name:	Forgotten Password
Summary:	Considering the specific nature of the tool, users shall request a password reset to the country administrator.
Basic Flow:	1. The administrator selects the user to reset the corresponding password. 2. The administrator generates a new temporary password for the user. 3. At the next logon, the user is forced to change the password.
Alternative Flows:	1a. if the username does not exist, go to step 1
Pre-conditions:	The current user is an administrator.
Post-conditions:	The administrator resets the user’s password.

Table 5 Use case: User changes password.

Use Case Name:	User changes Password
Summary:	Users can change their own passwords.
Basic Flow:	1. The user goes to his profile. 2. The user inserts the old password and the new one. 3. The system saves the new password.
Alternative Flows:	N/A
Pre-conditions:	The current user knows the current (old) password.
Post-conditions:	The system changes the user password.

Table 6 Use case: Roles Management

Use Case Name:	Roles Management
Summary:	Admins can change the roles assigned to a user.

Basic Flow:	1. The admin retrieves the list of users. 2. The admin selects the wanted user. 3. The system returns all current roles of the users and possible new candidates. 4. The admin assigns or removes roles from the user. 5. The admin submits the changes. 6. The system saves the new configuration.
Alternative Flows:	None
Pre-conditions:	The current user has admin roles.
Post-conditions:	The target user has new capabilities corresponding to the new roles.

4.2 Assessment creation

Figure 6 Mock-up of assessment creation.

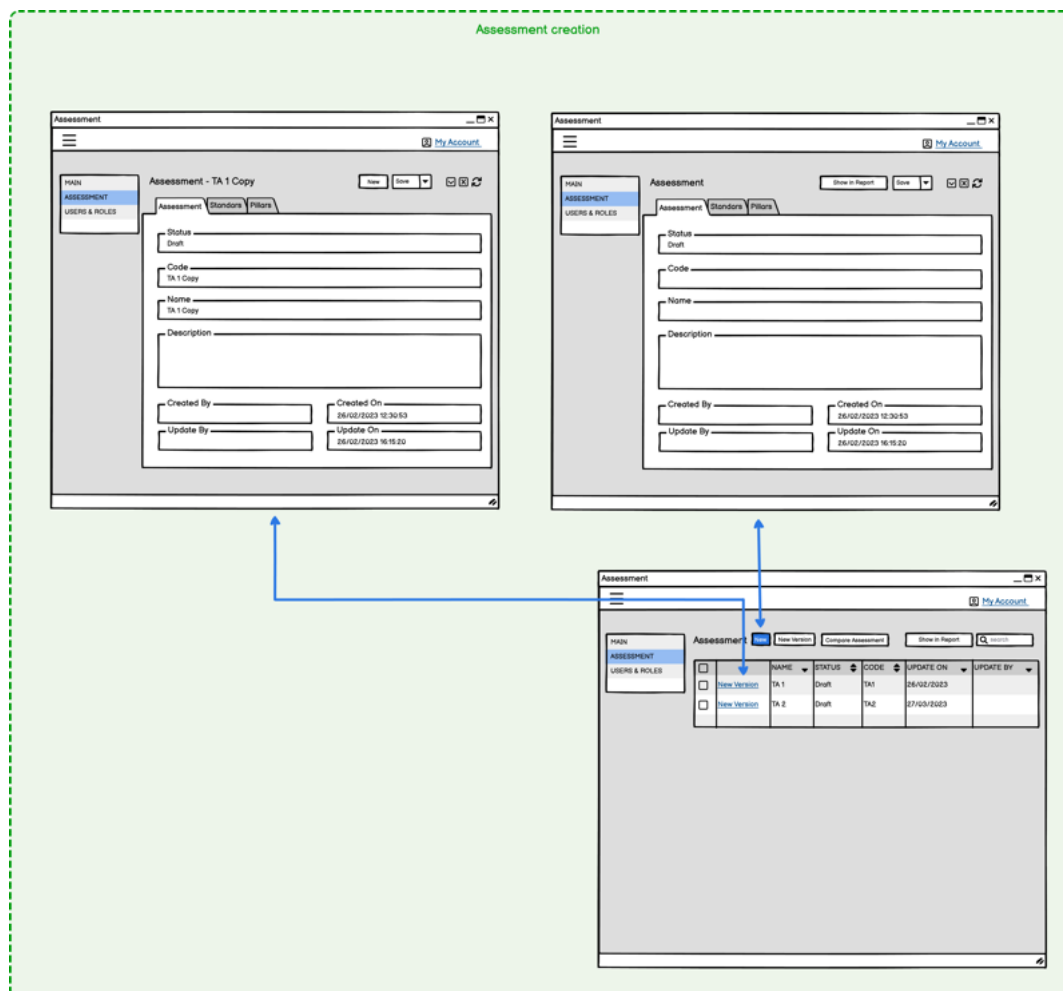


Table 7 Use case: Assessments Search

Use Case Name:	Assessments Search
Summary:	The user can only search and recall assessments he created. As an exception, if the user is external, he can also see public assessments in read-only mode.
Basic Flow:	1. The user wants to view an assessment. 2. The user search for an assessment using (part of) the name, date, and other fields. 3. The system retrieves the list of results from the set of assessments created by the user. 4. The user selects the wanted assessment
Alternative Flows:	3a. If the user is external, he can only see public assessments in read-only fashion.
Pre-conditions:	None
Post-conditions:	The user retrieves a list of assessments and selects the one he wants to access.

Table 8 Use case: Assessment Creation

Use Case Name:	Assessment Creation
Summary:	The user can create a new assessment either from scratch or a previous version. In both cases, the recent review will be linked to the current version of the hierarchy of metrics. The assessments deriving from earlier versions will automatically inherit the scores for the metrics and mechanisms which are still part of the hierarchy.
Basic Flow:	1. The user wants to create a new assessment. 2. The user enters assessment details (name, date, etc.) 3. The system generates a new assessment and links it to the current version of the hierarchy. 4. The user can now search and change mechanisms and metrics in the newly generated assessment
Alternative Flows:	1a. The user list previous assessments and choose one as the starting point for a new copy. 2a. The user enters additional details (name, date, etc.) 3a. The system generates a new assessment and links it to the current version of the hierarchy. 4a. The system tries to copy scores from previous assessment to compatible metrics which are still existing in the new one
Pre-conditions:	A hierarchy is available. Optionally, a previous assessment is available.
Post-conditions:	A new assessment is created for the user. The latter can now update its scores and compare it with other versions.

4.3 Assessment process

Figure 7 Mock-up of the assessment process, part 1.

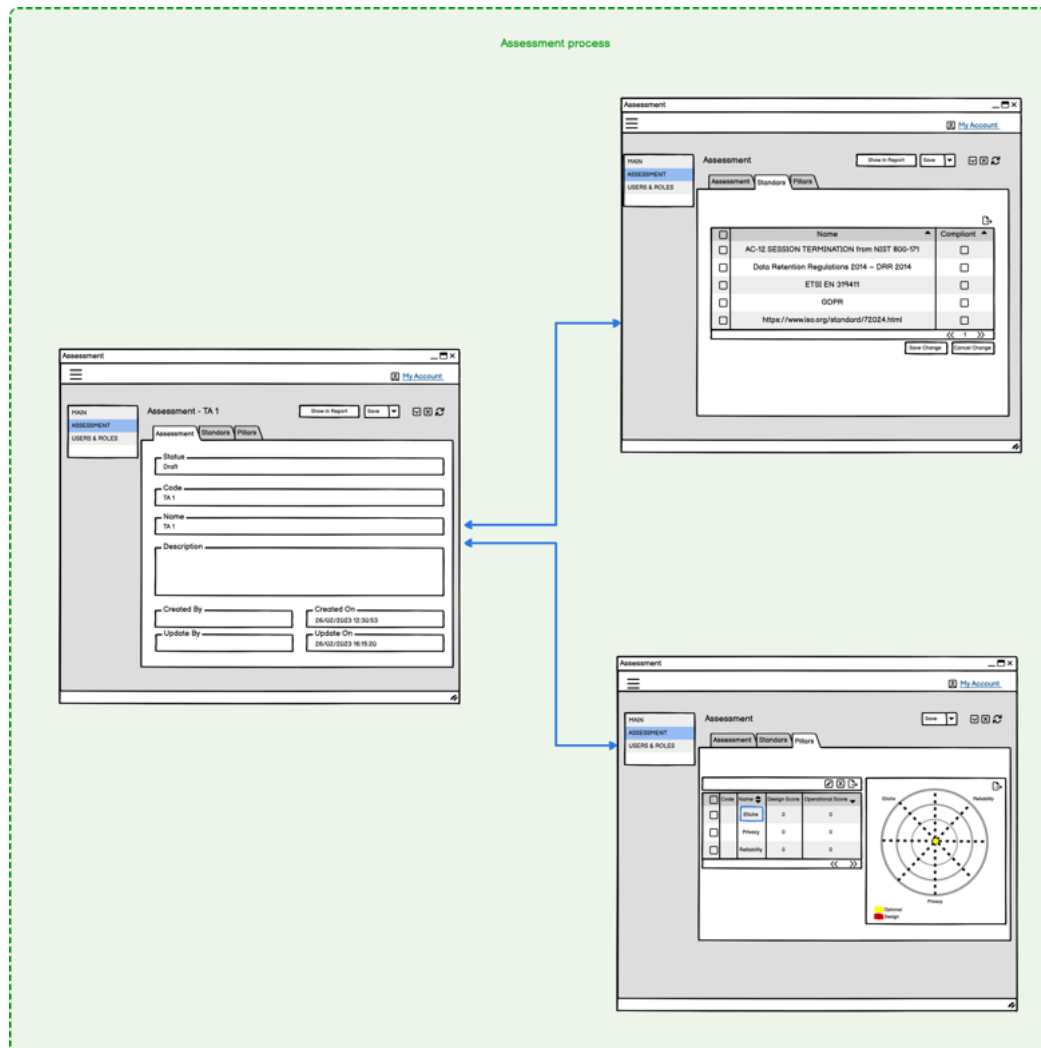


Table 9 Use case: Assessment Process, part 1

Use Case Name:	Assessment Process – Part 1
Summary:	The user can assign scores to metrics in assessments he created. First, the user selects the wanted assessments. By selecting standards, the user can pre-fill all corresponding metrics. When finished, the user can move to the pillar section.
Basic Flow:	1. The user wants to conduct the assessment. 2. The user recalls one assessment using the “Assessment Search” use-case. 3. The system retrieves the corresponding entry, with all side information available (description, links, etc.)

	- The user selects the standards tab and selects the entries to which the system is already compliant. (optional) The user saves the changes. - The user moves to the pillar section of the assessment.
Alternative Flows:	None
Pre-conditions:	An assessment is available.
Post-conditions:	All metrics corresponding to selected standards are pre-filled.

Figure 8 Mock-up of the assessment process, part 2.

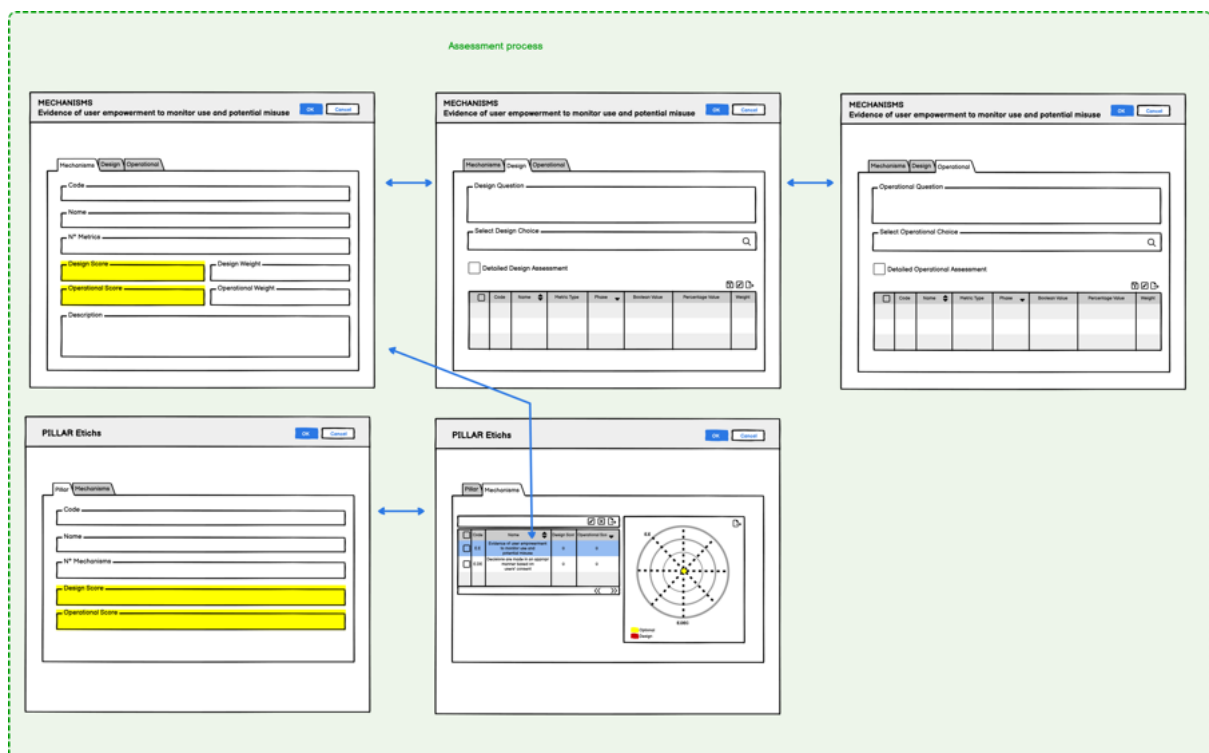


Table 10 Use case: Assessment Process, part 2

Use Case Name:	Assessment Process – Part 2
Summary:	The user selects a pillar of the chosen assessments, showing all the mechanisms. Mechanisms can be excluded from the assessment if necessary. Otherwise, from the design and/or operational tab, the user can select the pre-configured choice (if available). If he needs more degrees of freedom, the user can select the “Detailed assessment” checkbox and manually check/uncheck the metrics. When finished, the user must save all changes, all the way up to the assessment.
Basic Flow:	- The user selects a pillar and investigates the mechanisms. - The user selects a mechanism to see its details.

	3. By clicking on the design/operational tab, the user lists all the underlying metrics. 4. The user selects the mechanism choice, and automatically changes the configuration of the metrics. 5. The user saves the changes to the metrics. 6. The user saves the changes to the assessment.
Alternative Flows:	2a. The user excludes the mechanism from the assessment 4a. The user selects the checkbox “Detailed assessment”, enabling the possibility of changing the metric scores directly.
Pre-conditions:	An assessment is available.
Post-conditions:	All chosen metrics are assessed.

4.4 Reports and comparison

Figure 9 Mock-up of assessment report and comparison.

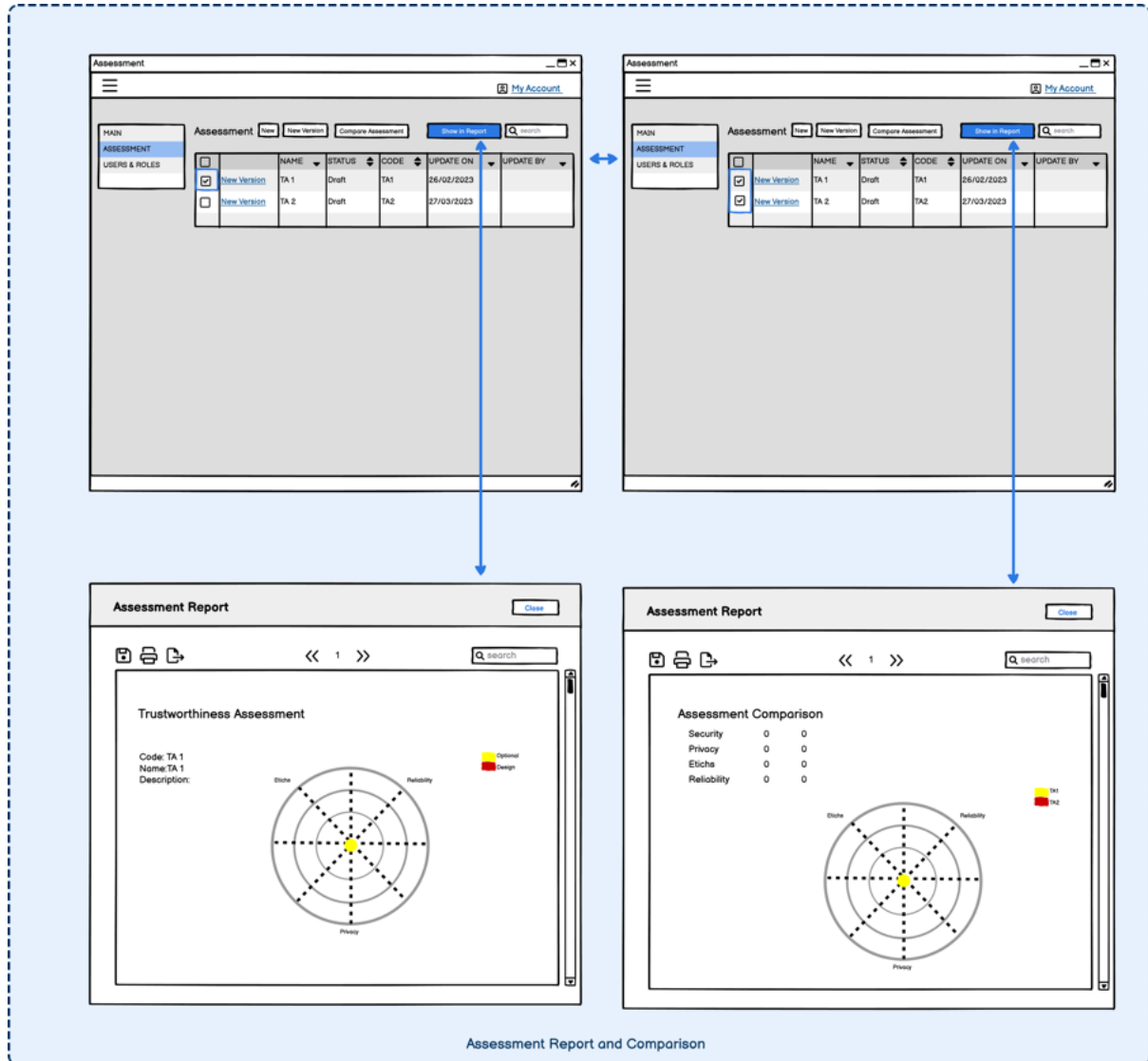


Table 11 Use case: Assessments Report

Use Case Name:	Assessments Report
Summary:	The user can export a report of the chosen assessment.
Basic Flow:	1. The user wants to view an assessment. 2. The user search for an assessment using the use-case "Assessment Search". 3. The user generates the report for that assignment.
Alternative Flows:	3a. If the user is external, he can only see public assessments in read-only fashion.
Pre-conditions:	None
Post-conditions:	The user generates a report for the assessment.

Table 12 Use case: Assessments Comparison

Use Case Name:	Assessments Comparison
Summary:	The user can compare two assessments, showing the different pillars/mechanisms and metrics scores. If the assessments derive from other versions of the hierarchy, only scores from the shared metrics (and weights) are considered.
Basic Flow:	1. The user wants to compare two assessments. 2. Using the use case “Assessments Search”, the user selects two assessments. 3. The user clicks on a “Compare” button to generate the comparison results, in form of a report.
Alternative Flows:	N/A
Pre-conditions:	At least two assessments are available.
Post-conditions:	The user visualises a comparison between two assessments, showing the different scores of pillars/mechanisms/metrics with the help of charts or other visual indicators.

5. Further information

In this report, we described the web tool to be used for assessing the Trustworthiness of Digital Identity Systems. An exhaustive list of use-cases was provided to cover all functional and non-functional objectives. Together with the mock-ups this provides insight into the functionality of the assessment tool.

For further background on the DISTAF process you can read:

- Facets of Trustworthiness in Digital Identity Systems
https://www.turing.ac.uk/sites/default/files/2021-05/technical_briefing-facets_of_trustworthiness_in_digital_identity_systems.pdf

For further information and guidance on undertaking a self-assessment contact the project team at the Alan Turing Institute.

6. References

Coronel, C., & Morris, S. (2016). *Database systems: design, implementation, & management*. Cengage Learning.

Maple, C., Epiphaniou, G., & Kyatsandra Gurukumar, N. (2021). *Facets of Trustworthiness in Digital Identity Systems Technical Briefing*.

McKinsey Global Institute. (2019). *Digital identification: A key to inclusive growth*. www.mckinsey.com/mgi.

Appendix A: Reference documentation for security pillar metrics

- ACM Code of Ethics
- CCPA
- COBIT 2019
- ETSI European Norm (EN)
European Norm (EN) 319411
- ETSI European Norm (EN)
European Norm (EN) 319521
- General Data Protection
Regulation (GDPR)
- Guide to IPsec VPNs
- Guide to Intrusion Detection and
Prevention Systems (IDPS)
- Guidelines on Firewalls and
Firewall Policy
- IEC 62645:2014
- IEEE Ethically Aligned Design
- ISO/IEC 19011:2018
- ISO/IEC 22301:2019
- ISO/IEC 31000:2018
- ISO/IEC 15408
- ISO/IEC 17021-1:2015
- ISO/IEC 22301:2019
- ISO/IEC 27001:2022 (with
Amendment 1:2024)
- ISO/IEC 27002:2022
- ISO/IEC 27005:2018
- ISO/IEC 27006:2015
- ISO/IEC 27018:2019
- ISO/IEC 27031:2011
- ISO/IEC 27035:2016
- ISO/IEC 27701:2019
- ISO/IEC 31000:2018
- ISO/IEC 24760
- ISO/IEC 27005 InfoSec Risk
Management
- ISO/IEC 29115
- ISO/IEC 29146
- MAGERIT
- MAGERIT methodology
- MITRE CVSS
- NIST Special Publication 800-12
- NIST Special Publication 800-128
- NIST Special Publication 800-137
- NIST Special Publication 800-192
- NIST Special Publication 800-57
- NIST Special Publication 800-189
- NIST Special Publication 800-115
- NIST Special Publication 800-124
Rev. 1
- NIST Special Publication 800-30
Rev. 1
- NIST Special Publication 800-34
Rev. 1
- NIST Special Publication 800-40
Rev. 3
- NIST Special Publication 800-41
Rev. 1
- NIST Special Publication 800-50
- NIST Special Publication 800-53
Rev. 5
- NIST Special Publication 800-61
Rev. 2
- NIST Special Publication 800-82
Rev. 2
- NIST Special Publication 800-92
- NIST IR 7874
- NIST IR 7875
- NIST IR 7876
- OWASP (Open Web Application
Security Project) Guidelines
- https://csrc.nist.gov/glossary/term/policy_enforcement_point

Appendix B: Reference documentation for privacy pillar metrics

- Data Retention and Investigatory Powers Act 2014
- General Data Protection Regulation (GDPR)
- ISO/IEC 10003 (Quality management -- Customer satisfaction -- Guidelines for dispute resolution external to organizations)
- ISO/IEC 15489 (Information and Documentation - Records Management)
- ISO/IEC 11770-6:2016
- ISO/IEC 25010:2011
- ISO/IEC 25012 (Data Quality Model)
- ISO/IEC 27001:2022 (with Amendment 1:2024)
- ISO/IEC 27002:2022
- ISO/IEC 27018:2019
- ISO/IEC 27031 (Guidelines for information and communication technology readiness for business continuity)
- ISO/IEC 27701 (Privacy Information Management System)
- ISO/IEC 27701:2019
- ISO/IEC 29100:2011
- ISO/IEC 29115 (Entity Authentication Assurance Framework)
- ISO/IEC 29134 (Guidelines for privacy impact assessment)
- ISO/IEC 29192-1:2012
- NIST Privacy Framework
- NIST Special Publication 800-137 (Information Security Continuous Monitoring for Federal Information Systems and Organizations)
- NIST Special Publication 800-161 (Supply Chain Risk Management Practices for Federal Information Systems and Organizations)
- NIST Special Publication 800-186
- NIST Special Publication 800-192 (Verification and Test Methods for Access Control Policies/Models)
- NIST Special Publication 800-41 (Guidelines on Firewalls and Firewall Policy)
- NIST Special Publication 800-53 Rev. 5
- NIST Special Publication 800-57 (Recommendation for Key Management)
- NIST Special Publication 800-63A (Digital Identity Guidelines: Enrolment and Identity Proofing)
- NIST Special Publication 800-63B (Digital Identity Guidelines: Authentication and Lifecycle Management)
- NIST Special Publication 800-88 (Guidelines for Media Sanitization)
- ISO/IEC 10003 (Quality management - Customer satisfaction - Guidelines for dispute resolution external to organizations)
- eIDAS (Electronic Identification and Trust Services)
- <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-act>

Appendix C: Reference documentation for ethics pillar metrics

- IEEE 7000-2021
- ISO/IEC 27001:2022 (with Amendment 1:2024)
- ISO/IEC 27002:2022
- ISO/IEC 27701:2019
- ISO/IEC 29100:2011
- ISO/IEC 29134:2017
- ISO/IEC 18033 (Encryption algorithms)
- NIST Special Publication (SP) 800-50 (Building an Information Technology Security Awareness and Training Program)
- NIST Special Publication (SP) 800-53 (Security and Privacy Controls for Federal Information Systems and Organizations)

Appendix D: Reference documentation for robustness pillar metrics

- ISO/IEC 22301:2019
- ISO/IEC 25010:2011
- ISO/IEC 27001:2022 (with Amendment 1:2024)
- ISO/IEC 27002:2022
- ISO/IEC 27005:2018
- ISO/IEC 27017:2015
- ISO/IEC 27018:2019
- ISO/IEC 27031:2011
- ISO/IEC 29100:2011
- NIST Special Publication (SP) 800-53 Rev. 5
- OWASP (Open Web Application Security Project) Guidelines

Appendix E: Reference documentation for resilience pillar metrics

- ISO/IEC 27001:2022 (with Amendment 1:2024)
- ISO/IEC 27002:2022
- ISO/IEC 27031:2011
- ISO/IEC 27035:2016
- ISO/IEC 27036-3:2013
- ISO/IEC 29100:2011
- MITRE resilience catalogue
- NIST Special Publication (SP) 800-160 Vol. 2
- NIST Special Publication (SP) 800-34 Rev. 1
- NIST Special Publication (SP) 800-53(r4)
- NIST Special Publication (SP) 800-61 Rev. 2

Appendix F: Reference documentation for reliability pillar metrics

- ISO/IEC 19011 (Guidelines for auditing management systems)
- ISO/IEC 22301:2019
- ISO/IEC 24760 51
- ISO/IEC 30401:2018
- ISO/IEC 31000:2018
- ISO/IEC 17065 (Conformity assessment -- Requirements for bodies certifying products)
- ISO/IEC 27001:2022 (with Amendment 1:2024)
- ISO/IEC 29115:2013
- ISO/IEC TS 29003
- NIST Special Publication (SP) 800-53 (Security and Privacy Controls for Federal Information Systems and Organizations)
- NIST Special Publication (SP) 800-92 (Guide to Computer Security Log Management)
- eIDAS
- <https://www.fatf-gafi.org/media/fatf/documents/recommendations/pdfs/Guidance-on-Digital-Identity-report.pdf>